

[Back](#)

An updated version of this article is available ([kb_view.do?sys_kb_id=1b8f7d611b0bf590ca7320ea234bcbd3](#)). You can only edit the latest version of the article

Copado SecAPI Integration

KB0100288 - [v5.0](#) (Outdated)

☆☆☆☆☆ 17 views

KBB0015394

HPE Feedback (HPE KB)

KBB0015392

HPE Honeycomb Logo (HPE KB)

Overview

Integrating all the required code quality and security checks deemed by the Enterprise is a key component of Humana's Salesforce Copado DevOps transformation strategy. One of the most important checks our Salesforce code goes through prior to Production release is the static Checkmarx scan (Security SAST scan). This scan ensures that code that is being pushed to Production is free of security violations that put our members', business partners', and Humana's own data at risk.

Prior to June '21, this scan occurred on either a scheduled or ad-hoc basis against the SIT and UAT equivalent branches for our Salesforce Orgs. In some cases, executing the scan took a lead time of ten days before the job would be picked up by the Sparq team. Developers had to wait until their code was promoted to higher environments to have any insight into whether their code contained any security violations, often leading to last-minute crunch to remediate before the Production turn.

Now, in the interest of shifting code scanning as left as possible, security scans are available at User Story level itself. Also, Security scans for Release branch (PROD-1 level in Pipeline) can be performed directly from Copado, for Orgs adopting GLAPI Certified Pipelines.

Orphan Branch vs Feature Branch

- **Feature Branch:** Each User Story within Copado is a Feature Branch, which is based off main branch and includes recent commits + history of main branch.
- **Orphan Branch:** This is a temporary branch created out of Feature Branch on the fly, which comprises of differences only i.e. code delta.
- Scanning Orphan Branch at User Story level, reduces scan times significantly. Copado takes care off creating one, when scan request is initiated.

Getting Started

There are couple of pre-requisites, before a developer can get started with scanning their user stories or DevOps team member can scan a release branch.

- **Generating API Key** Please make sure to generate API key before starting the SecAPI Scan. This is a one time activity. It can be generated by navigating to Copado Home page >> Account Summary within App Launcher >> API Key.

- **SecAPI Project to scan Orphan Branches** For each Salesforce Org using Copado Pipelines, a dedicated SecAPI Project has been setup (with same presets as existing Checkmarx Profile), which will be used for scanning Orphan Branches only. Each Copado Project for respective Pipeline, will have SecAPI APP ID key listed on it.

Note 1: E3 is responsible for setting up SecAPI project setup for Orphan branch scans and updating Copado Projects per Pipeline with SecAPI App ID.

Note 2: When a new Copado project gets added to your pipeline, please reach out to E3 for getting Orphan project SecAPI App Id updated.

Note 3: Field SecAPI Orphan App Id can only be edited by System Admins.

ORG	ORPHAN PROJECT NAME	SECAPI URL
B2B GROUP CRM	B2B_Copado_Orphan	https://appsec.humana.com/Dashboard/5984432b-73fb-4bb1-834a-8069f697c679 (https://appsec.humana.com/Dashboard/5984432b-73fb-4bb1-834a-8069f697c679)

Corporate Initiatives	CI_Copado_Orphan	https://appsec.humana.com/Dashboard/dd9a9df5-07a9-4164-8e21-aa28046a8415 (https://appsec.humana.com/Dashboard/dd9a9df5-07a9-4164-8e21-aa28046a8415)
Clinical ECOM	Clinical_Copado_Orphan	https://appsec.humana.com/Dashboard/e8c99527-cf97-42fc-91c8-cae94f786ca1 (https://appsec.humana.com/Dashboard/e8c99527-cf97-42fc-91c8-cae94f786ca1)
PCO	PCO_Copado_Orphan	https://appsec.humana.com/Dashboard/067fe6e8-18f4-423d-908e-adca84b62f45 (https://appsec.humana.com/Dashboard/067fe6e8-18f4-423d-908e-adca84b62f45)
CarePlus	CarePlus_Copado_Orphan	https://appsec.humana.com/Dashboard/1cd049fd-8589-413a-9a4c-ff0297cacfb8 (https://appsec.humana.com/Dashboard/1cd049fd-8589-413a-9a4c-ff0297cacfb8)

SecAPI Security Scans at User Story Level

- Developers will be required to submit all user stories to Checkmarx and receive a passing grade (no High or Medium violations) prior to deployment to the next environment outside of their Dev box.
- Overall, process is split across 2 parts. Creation of Orphan Branch followed by initiating SecAPI scan on it.
- Scan can be initiated by bringing up dropdown on User Story layout page, click on **SecAPI Scan** and then click on **Run New Scan**.
- After initiating the scan, developer can come out of popup window and continue working as scan is running in background. To check the scan progress, developer can click back on **SecAPI Scan** to get the popup, and then **Check Scan Status**.
- Developer can leverage **SecAPI Scan Status & Orphan Branch Status** on details tab on User Story.
- Scan results can be viewed on Related tab, SecAPI Scan Results. This section will reflect count of High, Medium or Low issues per recently completed scan, along with scan duration, link to PDF version of Scan report and other important details.
- **Definition of Done** section on Details tab, now includes a checkbox for **SecAPI Scan Passed**.
- If a story's scan returns with medium or high violations a validation rule will block deployment until the issues are resolved and a new passing scan is returned.
- Predominantly **Developers** are affected, while DevOps should be aware of the additional definition of done criteria, updates to the user story layout, and the validation rule for dev sandbox exit.

Refer screenshots below for complete flow:

User Story
US-0027725

Edit

Commit Changes

Open Org

▼

Humana Org ⓘ	Stop Indexing Metadata ⓘ
B2B	
copado BoardColumn	Base Branch ⓘ
SecAPI Scan Status	Git Merge Status ⓘ
Not Started	
Orphan Branch Status	Close Date
	Azure PR Link
	Peer Review Status

▼ Agile content

Submit

Validate Changes

Manage Apex Tests

Run Static Code Analysis

Manage Selenium Tests

Run Compliance Scan

Add Commits

Open Pull Request

Submit for Approval

SecAPI Scan

User Story
US-0027725

Humana Org 

B2B

copado BoardColumn

SecAPI Scan Status
Not Started

Orphan Branch Status

Agile content

As a...

SecAPI Scan

USER STORY DETAILS

User Story Id	Project Name
US-0027725	B2B Dental Network Mgmt Team
User Story Title	Orphan Branch Status
Dummy Story for Testing SecApi	Not Started

SECAPI RUNNING STATUS

Scan Not Started **0% Completed**

Run New Scan

Check Scan Status

Close

User Story
US-0027725

Humana Org 

B2B

copado BoardColumn

SecAPI Scan Status
Not Started

Orphan Branch Status

Agile content

As a...

Want to...

Developer

SecAPI Scan

USER STORY DETAILS

User Story Id	Project Name
US-0027725	B2B Dental Network Mgmt Team
User Story Title	Orphan Branch Status
Dummy Story for Testing SecApi	In Progress : Started

SECAPI RUNNING STATUS

Scan Not Started

0% Completed

Run New Scan

Check Scan Status

Please wait! Orphan branch is getting created.

Close

User Story
US-0027725

Humana Org ⓘ
B2B

copado BoardColumn

SecAPI Scan Status
Not Started

Orphan Branch Status
Completed

Agile content

As a...

Want to...

Developer

SecAPI Scan

USER STORY DETAILS

User Story Id	Project Name
US-0027725	B2B Dental Network Mgmt Team
User Story Title	Orphan Branch Status
Dummy Story for Testing SecApi	Completed

SECAPI RUNNING STATUS

Scan Not Started

25% Completed

Run New Scan

Check Scan Status

Please click on Check Scan Status button to continue with the SecAPI scan

Close

User Story
US-0027725

Humana Org 

B2B

copado BoardColumn

SecAPI Scan Status

In-Progress

Orphan Branch Status

Completed

▼ Agile content

As a...

Want to...

Developer

SecAPI Scan

USER STORY DETAILS

User Story Id	Project Name
US-0027725	B2B Dental Network Mgmt Team
User Story Title	Orphan Branch Status
Dummy Story for Testing SecApi	Completed

SECAPI RUNNING STATUS

Scan In-Progress (ACCEPTED) 50% Completed

Run New Scan

Check Scan Status

Please wait, button will be re-enabled after 30 seconds

Close

User Story
US-0027725

Humana Org ⓘ

B2B

copado BoardColumn

SecAPI Scan Status

In-Progress

Orphan Branch Status

Completed

▼ Agile content

As a...

Want to...

Developer

SecAPI Scan

USER STORY DETAILS

User Story Id	Project Name
US-0027725	B2B Dental Network Mgmt Team
User Story Title	Orphan Branch Status
Dummy Story for Testing SecApi	Completed

SECAPI RUNNING STATUS

Scan In-Progress (RUNNING) **50% Completed**

Run New Scan

Check Scan Status

Please wait, button will be re-enabled after 30 seconds

Close

User Story
US-0027725

Humana Org ⓘ

B2B

copado Board/Column

SecAPI Scan Status
✓ Completed

Orphan Branch Status
✓ Completed

▼ Agile content

As a...

Want to...

Developer

SecAPI Scan

USER STORY DETAILS

User Story Id	Project Name
US-0027725	B2B Dental Network Mgmt Team
User Story Title	Orphan Branch Status
Dummy Story for Testing SecApi	Completed

SECAPI RUNNING STATUS

Scan Completed (FINISHED) **100% Completed**

Check SecAPI Scan Results section in the related list on User Story for Scan response.

Run New Scan Check Scan Status

Close



User Story
US-0027725

Details Commits Quality Promotions **Related**



Bundled Stories (0)

New



Apex Test Results (0)



SecAPI Scan Results (6+)

SecAPI Scan Result Name

High

Medium

Low

[00000721](#)

0

1

1





SecAPI Scan Result
00000721

Related **Details**

SecAPI Scan Result Name

00000721

Scan Type

sast

Copado User Story

[US-0027725](#)

Owner

 [Gaurav Jaju \(Copado\)](#)

Submitted Date

2/14/2022 5:04 PM

Last Updated

2/14/2022 5:10 PM

Error Message

Scan Status

Callout 3 Completed

Scan Duration

5.68

Promotion

Release Copado

Build Id

0000000163

Repo Branch

SecAPI Scan Id

bce487f2-11d1-482b-bccb-f2197a57c616

 SecAPI Scan Result
00000721

▼ SecAPI Scan Score

High	Medium
0	1
Scan Failed ⓘ	Low
☒	1

▼ SecAPI Scan Report

[View SecAPI Scan Report](#)

Created By
 [Gaurav Jaju \(Copado\)](#), 2/14/2022 5:04 PM

Last Modified By
 [Gaurav Jaju \(Copado\)](#), 2/14/2022 5:10 PM

US-0027725 | Salesforce

humanashared.lightning.force.com/lightning/r/copado_User_Story_c/a3p3c0000015kWEAAY/view

Copado Release Ma... Home Getting Started Deployments Snapshot Differences Credentials Git Repositories Git

▼ Definition of Done

Documentation Complete	Manual Tests Passed
☐	☐
Pull Requests Approved	Apex Tests Passed
☐	☐
Static Code Analysis Passed	SecAPI Scan Passed
☐	☐

Benefits of scanning early

- **No lead time required to receive a scan** - Scans submitted for SecAPI are immediately sent into a queue to be picked up by Checkmarx scan engine workers. As soon as a worker is available to scan your feature branch the request is executed. In some cases, this saves developers days of waiting. The duration your scan request sits in the queue is dependent on the time of day it is submitted. During IST working hours we've seen scans take 2-3 minutes to execute, while during EST working hours they can take upwards of 10-15 minutes before the job is picked up. This is entirely due to the load on the Checkmarx scan engines differing based on time zones.
- **Insight into scan results early to reduce rework** - By scanning early at the user story level, Dev teams can be certain that the changes that they are responsible for should not be the cause of violations in higher environments, reducing the need to refactor or remediate later in the development lifecycle.



Revised by Regin Kanagappa
Last modified 6 weeks ago